

Vaughn Darreill B. Pereyra

IT3R12

Part A

What authorization model did you apply?

The authorization model used is Role Based Access Control.

Why is this model appropriate for the system?

This model fits the system because there are clear roles such as admin, faculty, and student and each role has its own responsibilities. It makes managing access easier since permissions are assigned by role instead of per user and it is easier to maintain as more users are added.

Part B

What is the threat and mitigation if the login API has no rate limiting?

The threat is that attackers can try many password combinations to gain access. The mitigation is to limit the number of login attempts and temporarily lock accounts after several failed tries.

What is the threat and mitigation if the API returns all user data?

The threat is that sensitive information may be exposed. The mitigation is to only return the necessary data by filtering fields in the API.

What is the threat and mitigation if HTTP is used instead of HTTPS?

The threat is that data can be intercepted while being transmitted. The mitigation is to use HTTPS so that data is encrypted during transfer.

Part C

Which encryption method will you use for passwords, stored grades, and API communication?

Passwords will use hashing with salt such as Argon2 or bcrypt. Stored grades will use encryption such as AES. API communication will use HTTPS.

Why are these choices appropriate?

Passwords are hashed so they cannot be easily recovered if stolen. Grades are encrypted because they need to be accessed by authorized users. HTTPS is used to protect data while it is being sent between the client and server.

Part D

Why is security considered a continuous process rather than a one time implementation?

Security is continuous because new threats and vulnerabilities appear over time and systems also change as new features are added. Regular updates, monitoring, and checks are needed to keep the system protected.